

Manual 33 — Implementación controlada de Gobierno y Divulgación de Ciberseguridad de la SEC

****Idioma:**** Español de América Latina (es-419)

****Línea base regulatoria:**** SEC Release No. 33-11216, Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure, vigente desde el 5 de septiembre de 2023, con formularios y materiales oficiales de la SEC reverificados el 31 de agosto de 2026.

****Límite controlado:**** Esta edición es una traducción no oficial y una guía de implementación. No brinda asesoría jurídica, no determina estatus de emisor ni materialidad, no autoriza retrasos de divulgación, no presenta formularios ni certifica cumplimiento. Se mantienen separados reglas/formularios vinculantes, guía de la SEC, propuestas no efectivas, hechos de enforcement y práctica del emisor.

Chapter 01 — Propósito, alcance y jerarquía controlada de fuentes

Use reglas y formularios vigentes de la SEC como capa vinculante. Trate guías, compliance guides, speeches, FAQs, enforcement, petitions y proposals conforme a su verdadero estatus jurídico y fecha; los procedimientos internos nunca deben presentarse como reglas de la SEC.

Chapter 02 — Estatus del emisor y análisis de aplicabilidad

Mantenga una evaluación documentada del tipo de registrant, condición bajo Exchange Act, tratamiento de domestic issuer versus foreign private issuer, formularios aplicables, calendario de reportes y propietarios de disclosure controls. Escale dudas a counsel de securities calificado.

Chapter 03 — Definiciones y gobierno terminológico

Mantenga un glosario controlado para cybersecurity incident, cybersecurity threat, information systems, materiality, board oversight, management role, disclosure controls, Forms 8-K/6-K/10-K/20-F, Regulation S-K Item 106 e Inline XBRL. Preserve el significado SEC cuando difiera la terminología interna.

Chapter 04 — Gobierno de ciberseguridad y supervisión del board

Documente cómo el board o committee responsable supervisa riesgos materiales de amenazas cibernéticas, incluyendo flujos de información, frecuencia, escalamiento, incidentes significativos, tendencias e informes de management. La evidencia debe respaldar la divulgación anual sin convertir materiales ordinarios del board en conclusiones jurídicas no sustentadas.

Chapter 05 — Roles y responsabilidad de management

Defina roles responsables de evaluar y gestionar riesgos materiales de ciberseguridad, incluyendo CISO/security, legal, finance, disclosure committee, investor relations, risk, technology y executive leadership. Conserve responsabilidades, experiencia, escalamiento y evidencia relevante para Item 106.

Chapter 06 — Integración con enterprise risk management

Integre identificación y tratamiento de cyber risk con ERM para evaluar efectos materiales y razonablemente probables de forma consistente con otros riesgos. Preserve vínculos entre risk records, business impact, strategy, financial reporting y disclosure workpapers.

Chapter 07 — Identificación y priorización de riesgos cibernéticos

Mantenga un proceso repetible para identificar, evaluar, priorizar y gestionar amenazas y efectos de negocio. Incluya third parties, incidentes previos, cambios tecnológicos, exposición de datos, interrupción operativa y consecuencias legales/regulatorias.

Chapter 08 — Gobierno de materialidad y registros de decisión

Use un proceso documentado y específico del emisor basado en estándares federales de securities law y participación apropiada de counsel. Preserve hechos, factores cuantitativos y cualitativos, incertidumbre, autoridad decisoria, timing y fundamento final.

Chapter 09 — Detección de incidentes y escalamiento

Establezca escalamiento interfuncional que conecte rápidamente security operations con legal, disclosure, finance, investor relations, privacy, business y executives cuando un incidente pueda ser material. Registre descubrimiento, hitos de investigación, impactos conocidos y disparadores de materiality review.

Chapter 10 — Proceso de decisión Form 8-K Item 1.05

Para domestic registrants, mantenga un proceso controlado para determinar si un cybersecurity incident fue determinado material y requiere Item 1.05. No use Item 1.05 solo porque un incidente sea internamente severo; el disparador es la determinación de materialidad del emisor.

Chapter 11 — Control del plazo de cuatro business days

Una vez determinado material un incidente, rastree el plazo general de cuatro business days para Form 8-K desde la fecha de determinación. Mantenga timestamps, calendario, responsables, cobertura de contingencia y evidencia de filing oportuno o retraso válido.

Chapter 12 — Límite del proceso de delayed disclosure y Attorney General

Trate el retraso por riesgo sustancial para national security o public safety como proceso específico regulado, no como decisión interna. Preserve análisis legal, comunicaciones gubernamentales, determinaciones escritas, extensiones, timing y confidencialidad.

Chapter 13 — Gobierno del contenido de divulgación del incidente

Redacte Item 1.05 alrededor de los aspectos materiales requeridos usando hechos verificados y evitando detalle técnico sensible innecesario. Mantenga soporte de fuentes, comentarios, aprobaciones, version history y controles sobre afirmaciones especulativas.

Chapter 14 — Controles de amendment y corrective disclosure

Monitoree hechos después del filing inicial y mantenga un proceso para amendments o corrective disclosure cuando corresponda. Preserve motivo, nuevos hechos, análisis jurídico, aprobaciones, versión presentada y enlace con la divulgación original.

Chapter 15 — Divulgación anual Regulation S-K Item 106

Mantenga workpapers anuales que respalden la descripción de procesos de cyber risk management, efectos materiales o razonablemente probables, board oversight y management roles. Reconcilie la narrativa con evidencia real de governance, risk, incidents y assurance.

Chapter 16 — Divulgación del proceso de risk management

Documente cómo el emisor evalúa, identifica y gestiona riesgos materiales de amenazas cibernéticas, integración con overall risk management, uso material de terceros y procesos de oversight de riesgos de third-party service providers.

Chapter 17 — Divulgación de board oversight

Respalde la divulgación anual con registros que demuestren cómo el board o committee recibe información y ejerce supervisión. Evite boilerplate sin soporte en minutes, materials, cadence o práctica real.

Chapter 18 — Divulgación de experiencia y rol de management

Mantenga evidencia sobre posiciones o committees responsables, experiencia relevante cuando se divulgue y procesos por los cuales management recibe información y reporta al board.

Chapter 19 — Límite Form 6-K para foreign private issuers

Mantenga análisis separado de obligaciones de Form 6-K y su relación con divulgación/publicidad en jurisdicción extranjera, stock exchange o security holders. No aplique automáticamente la mecánica doméstica de Form 8-K.

Chapter 20 — Límite Form 20-F para foreign private issuers

Mantenga workpapers anuales de Form 20-F para risk management, strategy y governance aplicables a FPIs. Reconcilie terminología y timing al formulario vigente.

Chapter 21 — Controles de Inline XBRL tagging

Aplique requisitos vigentes de Inline XBRL. Mantenga taxonomy/version control, revisión de tagging, validation evidence, filing previews, correcciones y coordinación con filing vendors/systems.

Chapter 22 — Disclosure controls and procedures

Incorpore cybersecurity disclosure en los disclosure controls. Defina captura de información, escalamiento, materiality review, drafting, approval, filing, evidence retention, testing, deficiency management y reassessment periódico.

Chapter 23 — Coordinación legal, investor relations, security y executives

Mantenga un protocolo interfuncional que preserve security facts, legal judgment, market communications, financial implications y executive accountability. Defina decision rights y disponibilidad de emergencia antes del incidente.

Chapter 24 — Preservación de evidencia y disclosure workpapers

Conserve hechos del incidente, source records, materiality analyses, drafts, approvals, filing timestamps, evidencia de board/management, soporte anual y control testing en una estructura trazable con acceso y retención adecuados.

Chapter 25 — Consideraciones de incidentes y dependencias de terceros

Incluya third-party systems, cloud providers, processors, vendors y dependencias materiales. Registre ownership, notification, business impact, data exposure, contractual rights, limitaciones de investigación y materiality específica del emisor.

Chapter 26 — Consideraciones de cyber insurance y risk transfer

Trate insurance, indemnity y risk transfer como contexto de gestión, no como sustitutos de incident response o disclosure. Preserve coverage facts, limitations, recoveries/exposures materiales y coordinación con disclosure/financial reporting.

Chapter 27 — Interfaz con enforcement, litigation e investigation

Rastree developments de enforcement, litigation, investigations e interpretive material como evidencia fechada. No convierta alegaciones, settlements o rulings específicos en requisitos universales sin análisis jurídico.

Chapter 28 — Controles de confidentiality, privilege y need-to-know

Coordine con counsel la preservación de privilege, work product, market-sensitive information y security-sensitive technical facts. La confidencialidad no debe obstruir divulgación o retención requerida.

Chapter 29 — Métricas, reporting y continuous improvement

Defina métricas para incident escalation timing, materiality-review cycle time, disclosure readiness, control testing, disponibilidad de información de terceros, calidad de evidencia anual, filing defects y remediation. Use tendencias para mejorar gobierno, no como prueba aislada de compliance.

Chapter 30 — Revisión independiente y disclosure assurance

Use revisión legal, internal audit, compliance o control assurance independiente según corresponda. Preserve scope, independence, samples, findings, limitations, remediation y closure; no describa revisión interna como aprobación SEC.

Chapter 31 — Arquitectura de evidencia, trazabilidad y retención

Mantenga trazabilidad desde rule/form requirement hasta policy, procedure, owner, system, incident, materiality decision, disclosure workpaper, filing, control test, finding, remediation y source version. Aplique retención y acceso según securities law y demás requisitos aplicables.

Chapter 32 — Reverificación de fuentes y roadmap de implementación

Antes de cada release, reverifique Release 33-11216, Forms 8-K/6-K/10-K/20-F, Regulation S-K Item 106, Inline XBRL, guía SEC vigente y amendments efectivos. Registre cambios, impacto, controles actualizados, training, workpapers y acciones mediante change governance.

Conjunto mínimo de evidencia de implementación

Mantenga, según corresponda: issuer/applicability assessment; registro de fuentes SEC; governance y management accountability; cyber-risk register; materiality methodology y decisions; incident escalation; Item 1.05 decision/timing; delayed-disclosure records; drafts/approvals; Item 106 workpapers; FPI analysis; Inline XBRL validation; disclosure-control testing; coordinación legal/IR/security; third-party incident analysis; assurance findings; remediation y release-time source verification.